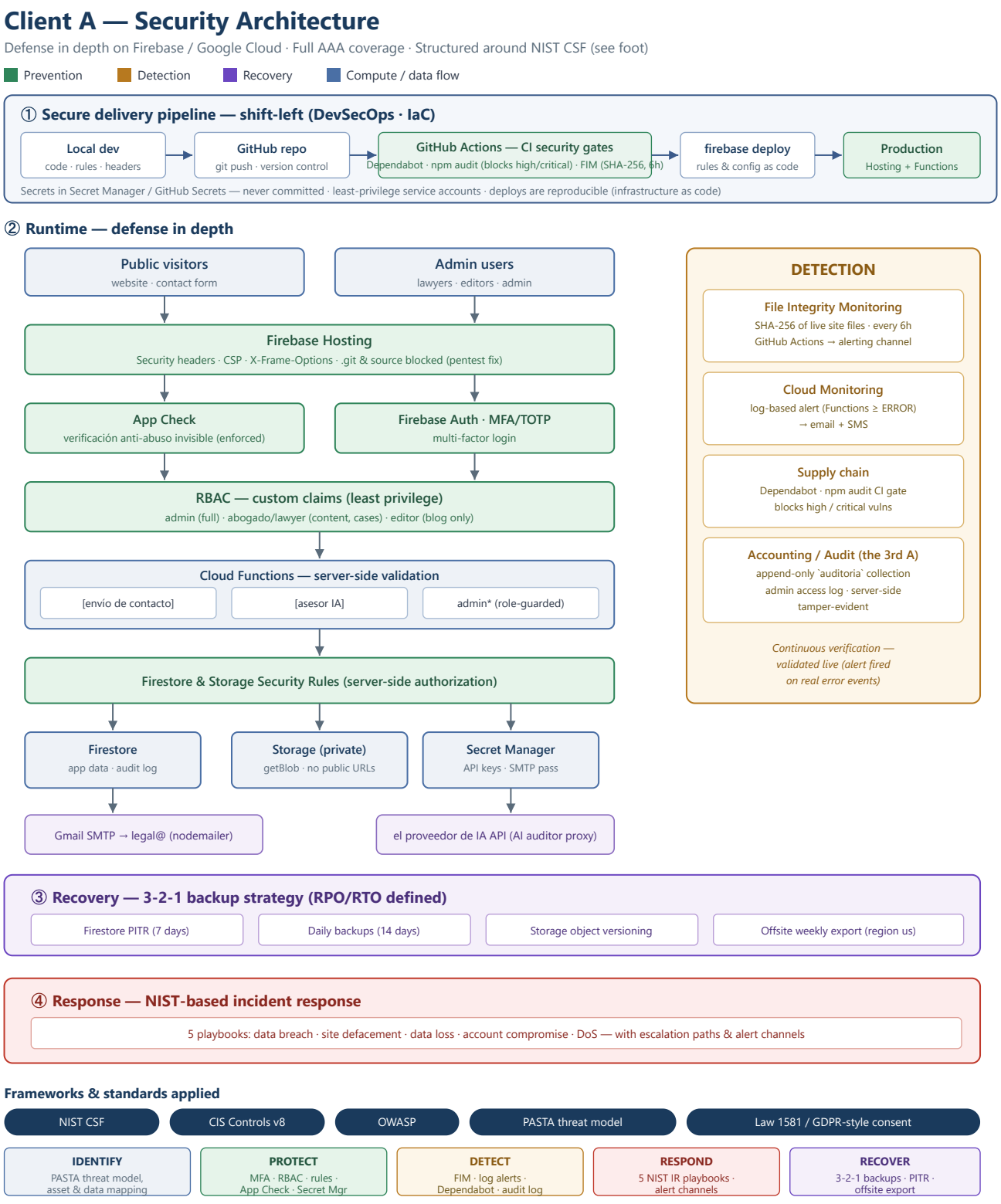
Security Portfolio — Belona Cybersecurity

Belona Cybersecurity LLC · Powder Springs, Georgia belonacyber.com · contact@belonacyber.com

> *Versión en español:* `espanol/README.md`
>
> **On anonymization.** The work documented here is real and was performed under authorization from the owner. The client's name and infrastructure identifiers were replaced with placeholders (`Client A` , `cliente-a`) before publication. **Belona Cybersecurity does not publish identifiable client data without written authorization** — the same rule we apply to every engagement.

Hardening a production legal-services web platform on **Firebase / Google Cloud** — end to end, as the sole technical owner. This folder documents the security engineering work: authentication, authorization, penetration testing with remediation, backups/DR, monitoring, threat modeling, and data-protection compliance — applying DevSecOps practices (security-as-code, CI security gates) throughout.

> **Start here:** `case-study-devsecops.pdf` — a 2-minute executive summary of the whole engagement.



Defense-in-depth architecture — prevention (green), detection (amber), recovery (purple).

Impact summary

AREA	WHAT WAS DELIVERED
Authentication	MFA/TOTP on the admin panel (resolved a session-timing enrollment blocker)
Authorization	Role-based access control (admin / lawyer / editor) enforced by Firestore & Storage security rules
Pentest	3-phase authorized test; found & remediated a **critical** `.git` + GitHub-token exposure served by Hosting
Abuse prevention	App Check + server-side rate limiting on the contact form
Hardening	Content-Security-Policy allow-list, security headers, secrets moved to a managed encrypted store
Recovery	3-2-1 backups: PITR (7d) + daily backups (14d) + object versioning + offsite weekly export
Detection	File Integrity Monitoring (SHA-256, every 6h) + Cloud Monitoring log alerts + Dependabot / `npm audit` CI gate
Secrets	API keys migrated from `.env` to Google Secret Manager
Compliance	Consent capture + proof; privacy-policy international-transfer clause (Colombia's Law 1581, analogous to GDPR/CCPA)

Result: full **AAA** coverage (Authentication, Authorization, Accounting) and defense in depth across prevention / detection / recovery — with **no added third-party attack surface** and **no added recurring cost**.

Documents

#	DOCUMENT	WHAT IT COVERS
1	Case Study — DevSecOps · ES	Executive overview of the full engagement (**read this first**)
2	Penetration Test Report · ES	Recon, authz testing, privilege-escalation attempts, findings & remediation
3	PASTA Threat Model (stages 3–7) · ES	Decomposition, threats, CWE/OWASP mapping, attack trees, residual-risk matrix
4	**Recovery capability** · ES	RPO/RTO, 3-2-1, and **a control documented as implemented that wasn't** — found by going to test the restore
5	**Email authentication: SPF, DKIM & DMARC** · ES	Staged rollout, reading the first DMARC report, and a DNS migration with **zero mail downtime**
6	**Hardening a contact form** · ES	Eight layers on a Cloudflare Worker, **each exercised with `curl` in production**
7	Incident Response Playbooks · ES	5 NIST-based playbooks (breach, defacement, data loss, account compromise, DoS)
8	Security Awareness Training · ES	7 modules mapped to CIS Control 14 / NIST CSF PR.AT

Each document is also available in Markdown (`.md`) alongside the PDF, and in Spanish under `espanol/`.

Tech stack

Cloud: Firebase (Hosting, Authentication / Identity Platform, Firestore, Storage, Cloud Functions), Google Cloud Platform, App Check, Secret Manager, Cloud Monitoring, Cloud Scheduler. **Security:** IAM / RBAC (custom claims), security rules as code, MFA/TOTP, penetration testing (nmap), File Integrity Monitoring (Python + GitHub Actions), Dependabot, PASTA threat modeling, NIST incident response.

Skills demonstrated

Cloud security (GCP/Firebase) · IAM & RBAC · security rules as code · penetration testing & remediation · secrets management · backup / disaster recovery (3-2-1, RPO/RTO) · detection engineering (FIM, log-based alerting) · supply-chain security · threat modeling (PASTA) · incident response (NIST) · security awareness · data-protection compliance (Law 1581 / GDPR-style).

Production platform: a Colombian law firm's public website + admin panel. Work performed by the sole technical owner as a self-directed Cloud Security / DevSecOps portfolio project.